Google Cloud Platform

# Three-Tier Application Platform

Architecture & Security Compliance Documentation

| | |
|---|---|
| **Document** | Project Design, Compliance & Deployment Reference |
| **Version** | 3.0 (Modular, Hardened, Deployed & Validated) |
| **Platform** | Google Cloud Platform |
| **IaC** | Terraform (8 modules) |
| **Status** | Deployed to GCP; smoke-tested with live workloads |
| **Classification** | Confidential — Internal Use |

Compliance frameworks referenced: CIS GCP Foundations Benchmark v2.0, ISO/IEC 27001:2022, SOC 2 (Trust Services Criteria), PCI-DSS v4.0.

# Table of Contents

# 1. Executive Summary

This document describes the architecture and security posture of a three-tier application platform deployed on Google Cloud Platform (GCP) and provisioned entirely through modular Terraform. The platform separates the presentation (frontend), application (backend) and data (database) tiers into isolated network segments, each with dedicated identity, autoscaling and health management, fronted by a global HTTPS load balancer protected by a Cloud Armor Web Application Firewall.

The design was refactored from a flat, single-directory Terraform configuration into seven reusable modules, and hardened to meet production-grade security and compliance objectives. Encryption with customer-managed keys (CMEK), least-privilege identity, private-only data access, default-deny networking, and centralized audit logging are applied throughout.

## Key outcomes

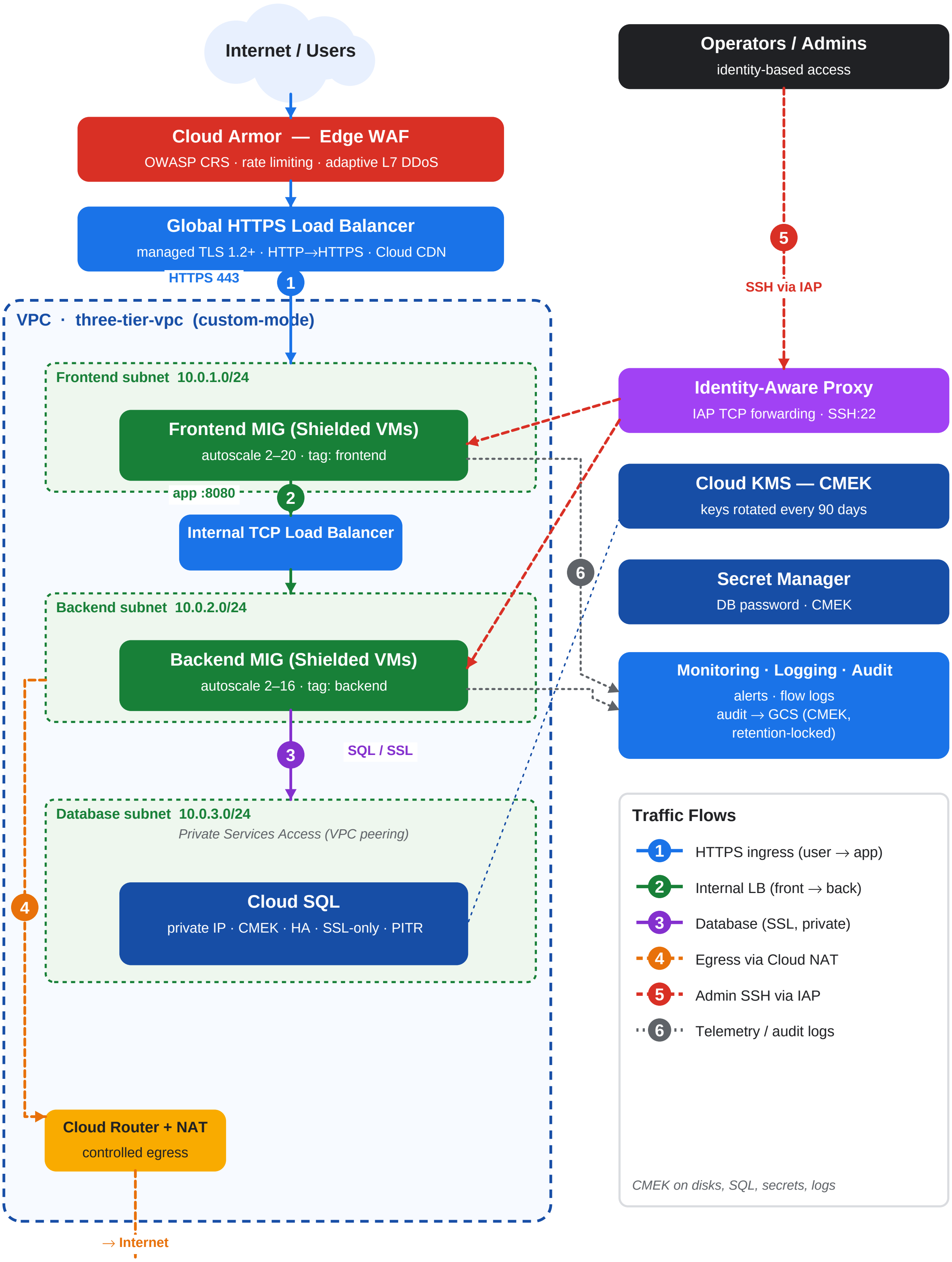
- **Modular & reusable:** a single generic compute module powers both application tiers; environments are driven by tfvars (dev/prod).
- **Encryption everywhere:** CMEK on disks, Cloud SQL, Secret Manager and the log archive bucket, with automatic 90-day key rotation.
- **Reduced attack surface:** no public IPs on instances, IAP-only SSH, default-deny firewall, and private-only Cloud SQL.
- **Edge protection:** Cloud Armor with OWASP Core Rule Set, per-client rate limiting and adaptive (ML) layer-7 DDoS defense.
- **Provable compliance:** controls mapped to CIS GCP, ISO 27001, SOC 2 and PCI-DSS (Section 9).
- **Deployed & validated:** provisioned to a live GCP project and smoke-tested with real workloads — nginx, Jenkins-in-Docker, and two containerised game platforms on a dedicated VM (Sections 13–14).

## Notable fixes applied during hardening

- Added **Cloud NAT** — the original design had neither public IPs nor NAT, so instances could not reach the internet to patch.
- Implemented **Cloud Armor**, which the original README described but never actually deployed.
- Removed a **duplicate KMS data source** that caused the original code to fail `terraform validate`.
- Replaced blanket `cloud-platform` trust with least-privilege IAM roles and enforced Shielded VM + OS Login.

# 2. Architecture Overview

Traffic flows from the internet through Cloud Armor and the global HTTPS load balancer to the frontend managed instance group. The frontend reaches the backend only through an internal load balancer; the backend reaches Cloud SQL only over a private, peered network path. Instances have no public IP and use Cloud NAT for controlled egress.



# 3. Module Design

The configuration is composed from the following modules under `modules/`. The composition root (`main.tf`) wires them together and expresses explicit dependencies (for example, API enablement before resource creation, and KMS IAM grants before Cloud SQL creation).

| Module | Responsibility | Primary Security Controls |
|---|---|---|
| project-services | Enable required Google APIs with a propagation wait | Minimal explicit API set |
| networking | VPC, per-tier subnets, firewall, Cloud NAT, private services access | Default-deny ingress, flow logs, IAP-only SSH, Private Google Access, NAT egress |
| security | CMEK key ring & keys, per-tier service accounts, Cloud Armor | Key rotation, least-privilege IAM, OWASP WAF, adaptive DDoS, rate limiting |
| compute | Reusable tier: instance template, MIG, autoscaler, health check | Shielded VM, CMEK disks, no public IP, OS Login, blocked project SSH keys |
| load-balancer | External global HTTPS LB + internal LB | Managed TLS, MODERN policy (TLS 1.2+), HTTP→HTTPS redirect, Armor attach |
| database | Cloud SQL primary/replicas + password secret | Private IP, CMEK, SSL-only, PITR, deletion protection, hardened flags |
| monitoring | Alerts, notification channel, audit archive | Audit log sink to CMEK bucket, DATA_READ/WRITE audit logging |
| game-server | Dedicated single-host VM for stateful container workloads | Shielded VM, CMEK disk, IAP-only SSH, static IP, scoped web ports |

## Composition & dependency ordering

- project-services → (networking, security) → compute tiers → load-balancer → database → monitoring.
- The database waits on both the private-services peering connection and the Cloud SQL service agent's CMEK grant to avoid race conditions.

# 4. Network Architecture

## Subnets (custom-mode VPC, regional)

| Tier | Subnet | CIDR | Public IP | Egress |
|---|---|---|---|---|
| Frontend | <env>-frontend-subnet | 10.0.1.0/24 | None | Cloud NAT |
| Backend | <env>-backend-subnet | 10.0.2.0/24 | None | Cloud NAT |
| Database | <env>-database-subnet | 10.0.3.0/24 | None (private IP) | n/a |

## Firewall rules (default-deny posture, all logged)

| Rule | Direction | Source | Target | Ports | Action |
|---|---|---|---|---|---|
| deny-all-ingress | Ingress | 0.0.0.0/0 | all | all | DENY (65534) |
| allow-frontend-from-lb | Ingress | GFE ranges | tag: frontend | 80,443 | ALLOW |
| allow-backend-from-frontend | Ingress | tag: frontend | tag: backend | 8080,8443 | ALLOW |
| allow-iap-ssh | Ingress | 35.235.240.0/20 | frontend,backend | 22 | ALLOW |
| allow-health-checks | Ingress | 130.211.0.0/22, 35.191.0.0/16 | frontend,backend | 80,443,8080,8443 | ALLOW |

- **No SSH from the internet** — administrative access is via Identity-Aware Proxy TCP forwarding only.
- **Public clients never reach the VMs directly** — only Google Front End / health-check ranges may reach the frontend; end users transit the load balancer.
- **VPC Flow Logs** enabled on every subnet; **Private Google Access** lets private instances reach Google APIs without egress to the internet.
- **Cloud SQL** is reachable only through Private Services Access (VPC peering); no public IP is assigned.

# 5. Identity & Access Management

Each tier runs under a dedicated service account granted only the roles it needs. Legacy broad access scopes are replaced with fine-grained IAM roles. Human access to instances requires OS Login and IAP.

| Principal | Roles | Rationale |
|---|---|---|
| frontend-sa | logging.logWriter, monitoring.metricWriter, monitoring.viewer | Emit logs/metrics only; no data access |
| backend-sa | + cloudsql.client, secretmanager.secretAccessor | Connect to Cloud SQL & read the DB password secret |
| Cloud SQL agent | cloudkms.cryptoKeyEncrypterDecrypter (SQL key) | Envelope-encrypt the database with CMEK |
| Secret Mgr agent | cloudkms.cryptoKeyEncrypterDecrypter (secret key) | Encrypt secrets with CMEK |
| Compute agent | cloudkms.cryptoKeyEncrypterDecrypter (disk key) | Encrypt boot disks with CMEK |

- Principle of least privilege enforced per tier.
- No user-managed service-account keys are created; workloads use attached identities.
- OS Login centralizes SSH authorization in IAM and ties access to org identity.

# 6. Data Protection & Encryption

All data at rest is encrypted with customer-managed keys (CMEK) in Cloud KMS, created in the deployment region and rotated automatically. Data in transit is protected by TLS at the edge and enforced SSL to the database.

| Asset | At Rest | In Transit | Key / Rotation |
|---|---|---|---|
| Compute boot disks | CMEK | n/a | disk key / 90 days |
| Cloud SQL | CMEK | SSL enforced (ENCRYPTED_ONLY) | sql key / 90 days |
| Secret Manager | CMEK | TLS (API) | secret key / 90 days |
| Audit log bucket | CMEK | TLS (API) | storage key / 90 days |
| External traffic | n/a | TLS 1.2+ (MODERN policy) | Google-managed cert |

- KMS crypto keys carry `prevent_destroy` to guard against accidental key loss (and data loss).
- The database password is randomly generated and stored only in CMEK-encrypted Secret Manager — never in plaintext state output.
- Cloud SQL enforces `ssl_mode = ENCRYPTED_ONLY` and IAM database authentication.

# 7. Edge Security (Cloud Armor / WAF)

The external backend service is protected by a Cloud Armor security policy attached at the global load balancer. The policy combines OWASP Core Rule Set signatures, per-client rate limiting, and adaptive layer-7 DDoS defense.

| Priority | Rule | Action |
|---|---|---|
| 1000 | SQL injection (sqli-v33-stable) | deny(403) |
| 1001 | Cross-site scripting (xss-v33-stable) | deny(403) |
| 1002 | Local/Remote file inclusion (lfi/rfi) | deny(403) |
| 1003 | Remote code execution (rce-v33-stable) | deny(403) |
| 2000 | Per-IP rate limit (throttle/ban) | rate_based_ban → deny(429) |
| — | Adaptive Protection (L7 DDoS ML) | auto-detect |
| MAX | Default | allow |

# 8. Logging, Monitoring & Audit

- **Cloud Audit Logs:** Admin Activity plus DATA_READ and DATA_WRITE data-access logs enabled for all services.
- **Log sink:** all `cloudaudit.googleapis.com` logs exported to a dedicated, versioned, retention-locked GCS bucket encrypted with CMEK.
- **VPC Flow Logs** and **firewall logging** provide network visibility.
- **Load balancer and health-check logging** enabled at 100% sample rate.
- **Cloud Monitoring:** high-CPU alert policy with email notification channel; auto-close after 30 minutes.
- **Cloud SQL Query Insights** enabled for performance and anomaly analysis.

The retention-locked bucket supports tamper-evident, WORM-style audit retention (default 365 days in prod), satisfying evidence-retention requirements for the frameworks in Section 9.

# 9. Security Compliance Mapping

## 9.1 CIS Google Cloud Platform Foundations Benchmark

| CIS Ref | Control | Implementation |
|---|---|---|
| 2.x | Logging & monitoring | Audit log sink, data-access logs, flow logs |
| 3.1 | Default network not used | Custom-mode VPC, no default network |
| 3.6/3.7 | No open SSH/RDP to 0.0.0.0/0 | IAP-only SSH; default-deny ingress |
| 3.9 | VPC Flow Logs enabled | Enabled on all subnets |
| 4.x | VM hardening | Shielded VM, OS Login, no public IP, serial off |
| 6.x | Cloud SQL hardening | Private IP, SSL-only, CMEK, secure flags |
| 1.x | IAM least privilege | Per-tier SAs, scoped roles, no SA keys |

## 9.2 ISO/IEC 27001:2022 (Annex A)

| Control | Theme | Implementation |
|---|---|---|
| A.5.15 | Access control | Least-privilege IAM, IAP, OS Login |
| A.8.24 | Use of cryptography | CMEK at rest, TLS in transit, key rotation |
| A.8.20 | Network security | Segmented subnets, default-deny firewall, NAT |
| A.8.16 | Monitoring activities | Audit logs, alerts, flow logs |
| A.8.15 | Logging | Centralized, CMEK, retention-locked archive |
| A.8.7 | Protection against malware | WAF/Cloud Armor OWASP rules |

## 9.3 SOC 2 (Trust Services Criteria)

| TSC | Criterion | Implementation |
|---|---|---|
| CC6.1 | Logical access | IAM least privilege, IAP, service accounts |
| CC6.6 | Boundary protection | WAF, LB, default-deny firewall, private DB |
| CC6.7 | Encryption of data | CMEK at rest; TLS/SSL in transit |
| CC7.2 | Detection & monitoring | Audit logs, alerts, adaptive DDoS |
| A1.1 | Availability | Regional HA (MIG + Cloud SQL REGIONAL), autoscaling |

## 9.4 PCI-DSS v4.0 (illustrative)

| Req | Requirement | Implementation |
|---|---|---|
| 1 | Network security controls | Segmentation, default-deny, private DB |
| 3 | Protect stored data | CMEK encryption; secrets in Secret Manager |
| 4 | Encrypt transmission | TLS 1.2+ at edge; SSL-only to DB |
| 6 | Secure systems/software | WAF, hardened images, IaC review |
| 8 | Identify & authenticate | IAM, OS Login, IAM DB auth |
| 10 | Log & monitor access | Audit logs to WORM archive; monitoring |

Mappings are indicative of control coverage provided by the infrastructure layer; full certification requires organizational controls, evidence collection and independent assessment.

# 10. Deployment Guide

## Prerequisites

- Terraform >= 1.3.0 and the Google Cloud SDK authenticated (`gcloud auth application-default login`).
- A GCP project with billing enabled and appropriate admin permissions.
- A GCS bucket for remote state (recommended; versioned + CMEK).

## Steps

Initialize (prod remote state)

```
terraform init -backend-config=environments/prod.gcs.tfbackend
```

Plan

```
terraform plan -var-file=environments/prod.tfvars
```

Apply

```
terraform apply -var-file=environments/prod.tfvars
```

Destroy (non-prod)

```
terraform destroy -var-file=environments/dev.tfvars
```

Environments are parameterized via `environments/*.tfvars`. Prod enables HTTPS (managed cert), Cloud CDN, regional HA Cloud SQL, read replicas and deletion protection.

# 11. Operations, HA & Disaster Recovery

## High availability

- Regional managed instance groups spread across three zones with autoscaling and auto-healing.
- Cloud SQL `REGIONAL` availability (synchronous standby) in prod; optional read replicas.
- Global HTTPS load balancer with health-checked backends and Cloud CDN.

## Backup & recovery

- Automated Cloud SQL backups (retained 30 in prod) plus binary-log point-in-time recovery.
- Versioned, retention-locked audit archive bucket.
- Rolling, zero-downtime instance-template updates (PROACTIVE, surge, substitute).

## Administrative access

```
gcloud compute ssh <instance> --zone <zone> --tunnel-through-iap
```

# 12. Risk Register & Roadmap

The current baseline addresses the major infrastructure risks. The following items are recommended to reach a fully certified posture:

| Area | Recommendation | Priority |
|---|---|---|
| Perimeter | Adopt VPC Service Controls to prevent data exfiltration | High |
| Org policy | Enforce org policies (no external IP, restrict SA key creation, uniform bucket access) | High |
| Supply chain | Enable Binary Authorization for container workloads | Medium |
| Threat detection | Enable Security Command Center Premium | High |
| Egress | Tighten Cloud NAT to specific subnets; add egress firewall rules | Medium |
| Secrets | Rotate DB credentials automatically via scheduled function | Medium |
| CI/CD | Add tfsec/Checkov + OPA policy gates to the pipeline | Medium |
| State | Confirm remote state bucket has versioning, CMEK and restricted IAM | High |

# 13. Application Workloads Deployed

The infrastructure was deployed to a live GCP project and validated end-to-end by running real workloads across every tier. This demonstrates the platform can host both stateless, autoscaled services and stateful, single-host container applications within the same project and VPC.

| Host / Tier | Workload | Access | Status |
|---|---|---|---|
| Frontend MIG | nginx static site | Global HTTPS load balancer (public IP) | Live — HTTP 200 |
| Backend MIG | Jenkins CI + Docker Engine | Internal LB :8080, IAP SSH | Healthy |
| Game server VM | WorkAdventure (Docker Compose: Traefik, play, back, map-storage, uploader, icon, redis) | https://<ip>.sslip.io (LetsEncrypt) | Live — 7/7 containers |
| Game server VM | Cloud-Morph (Go server + Wine container) | http://<ip>:8080 | Live — streaming Minesweeper |
| Database | Cloud SQL MySQL 8.0 (private, CMEK) | Backend tier only, private IP | RUNNABLE |

## Dedicated game server (single-host workloads)

- Provisioned by the `game-server` module: a single Shielded VM with a static public IP, CMEK boot disk and IAP-only SSH — deliberately outside the autoscaled MIG tiers because these apps are stateful and must run on one host.
- **No domain required:** the deploy uses `<ip>.sslip.io`, a real wildcard-DNS name resolving to the VM's IP, so Traefik obtains a valid Let's Encrypt certificate and WebRTC works without purchasing a domain.
- **Two apps coexist** on the VM: WorkAdventure on 80/443 (Traefik) and Cloud-Morph on 8080 — the latter opened via the module's `additional_web_ports` variable.

# 14. Deployment Notes & Operational Lessons

Deploying to a real (fresh, quota-limited) project surfaced several issues that were resolved and folded back into the modules. They are recorded here for operability and to inform future environments.

| Symptom | Root cause | Resolution |
|---|---|---|
| Instances could not fetch packages | No public IP and no NAT | Added Cloud NAT + Cloud Router for controlled egress |
| Startup scripts failed (exit 127) | CRLF line endings authored on Windows | Strip CR via replace(); .gitattributes enforces LF |
| Cloud Armor apply failed | New project SECURITY_POLICIES quota = 0 | Cloud Armor made optional (enable_cloud_armor); request quota to enable |
| Autoscaler apply failed | Regional INSTANCES quota = 8 | Right-sized dev autoscaling; request quota to scale |
| GCS CMEK grant failed | Storage service agent not yet created | Use google_storage_project_service_account data source + ordering |
| Jenkins never started | apt repo unsigned; package unavailable | Run Jenkins as a Docker container (jenkins/jenkins:lts-jdk17) |
| Backend tier auto-heal looped | Health check hit / (403) while Jenkins serves 8080 | Health path /login + longer initial delay |
| Cloud-Morph build failed | Debian Go 1.19 shadowed required Go 1.24 on PATH | Prepend official Go; purge apt Go; GOTOOLCHAIN=local |

## Operational access model

- **Terraform auth:** the provider authenticates with a short-lived token from the operator's gcloud session (`GOOGLE_OAUTH_ACCESS_TOKEN`), avoiding long-lived service-account keys.
- **Instance access:** all SSH is via Identity-Aware Proxy TCP forwarding (no public SSH). An `~/.ssh/config` ProxyCommand entry enables `ssh <instance>` and VS Code Remote-SSH.
- **Immutability:** MIG instances are ephemeral — durable changes are made to the Terraform templates and rolled, never by mutating live VMs.

Document generated for the modular, hardened, deployed Terraform baseline. Regenerate with `python docs/generate_pdf.py` after infrastructure changes.